

PHISHING EMAIL FORENSICS

Simulated SOC Investigation & Real-World IP Reputation Case Study

Analyst: Sojwal Jichkar
Date: 23 May 2026
Project Type: Training Exercise / Portfolio Project

Disclosure: Part 1 of this report uses a constructed training scenario, not a captured real-world email. Sender domain, phishing URL, and the IP address used in the simulated header are either invented or drawn from a documentation-reserved range (RFC 5737), so they do not point to real infrastructure. Part 2 uses a real, verifiable public IP address and genuine OSINT tool results, gathered independently of the simulated email.

EXECUTIVE SUMMARY

This report documents two related pieces of work: a simulated phishing email investigation built to demonstrate SOC L1 methodology (header analysis, IOC extraction, MITRE ATT&CK mapping, and response recommendations), and a real-world case study on IP reputation analysis using a genuine, independently verified IP address. The second part demonstrates a key analytical skill often missing from beginner SOC work: recognizing when a reputation score is misleading because the address in question belongs to shared infrastructure rather than a dedicated attacker.

PART 1 — SIMULATED PHISHING INVESTIGATION

1. Scenario Overview

A constructed email impersonating DocuSign was built to practice the analytical workflow used when triaging a suspected phishing report. The subject line ("Secure Document - Please Review") was designed to mimic a common real-world social engineering pattern: manufactured urgency intended to pressure a recipient into clicking before thinking critically.

2. Email Header Analysis (MXToolbox methodology)

Check	Result	Meaning
SPF	FAIL	Sending server was not authorized by the domain owner to send mail — sender is spoofed
DKIM	FAIL	No valid digital signature — message was not sent by the claimed organization
DMARC	FAIL	Domain's policy was violated; a real DocuSign message would not fail all three checks

3. Indicators of Compromise (Simulated)

IOC Type	Value	Note
Domain	docusign-secure.com	Look-alike domain impersonating docusign.com
Email	no-reply@docusign-secure.com	Spoofed sender — SPF/DKIM/DMARC all fail
URL	http://secure-docverify.com/login	Simulated credential-harvesting landing page
IP	203.0.113.55	RFC 5737 documentation range — placeholder, not a real attacker IP

4. MITRE ATT&CK Mapping

Tactic	Technique	Why It Applies
TA0001 Initial Access	T1566.002 Spearphishing Link	Email delivers a malicious link impersonating a trusted brand to harvest credentials
TA0001 Initial Access	T1036.005 Match Legitimate Name	Spoofed domain is deliberately built to resemble the real DocuSign brand name

5. Severity Rationale

Rated HIGH for the purposes of this exercise: full authentication failure across SPF, DKIM, and DMARC; explicit credential-harvesting intent; and impersonation of a brand (DocuSign) that is frequently and successfully targeted in real-world phishing campaigns due to its routine use in business document workflows. In a live environment, final severity would also weigh recipient count and whether any user interacted with the link before containment.

6. Recommended Actions

- Block sender domain (docusign-secure.com) at the email gateway
- Block phishing URL in the web proxy / secure web gateway
- Alert all users to the impersonation campaign
- Create a SIEM detection rule for inbound mail from the sender domain
- Escalate to L2 if any user is confirmed to have clicked the link

Note: IP blocking is intentionally not included as a Part 1 recommendation. As Part 2 demonstrates, blocking an IP without first verifying ownership can cause significant unintended impact.

PART 2 — REAL-WORLD IP REPUTATION CASE STUDY

7. Objective

To demonstrate why an analyst must verify IP ownership before recommending a block, using a real, independently verifiable IP address rather than a simulated one.

8. Investigation

Source	Finding
IP Address	185.199.108.153
VirusTotal Detection	3 / 91 security vendors flagged this IP as malicious (88 of 91 rated it clean)
VirusTotal Community Score	-26 (negative community sentiment despite low vendor detection)
ASN / Owner	AS 54113 — Fastly, Inc.
HTTP Response Headers	server: GitHub.com; via: 1.1 varnish (Fastly's caching layer)
Page Returned	404 — "Site not found · GitHub Pages"
AbuseIPDB	18 global abuse reports; 39% abuse confidence score
First Seen on VirusTotal	2018 — consistent with long-standing shared infrastructure, not a newly stood-up attacker server

9. Finding

This IP address belongs to Fastly, Inc. (AS 54113), and serves as shared CDN infrastructure for GitHub Pages — used by an enormous number of unrelated, legitimate websites. It is not a dedicated attacker-controlled server. The small number of automated vendor flags and the negative community score most likely stem from unrelated third parties hosting malicious

or spammy content on this same free, shared hosting platform at various points over time — not from this specific address being owned or operated by a threat actor.

10. Lesson Learned

- Abuse scores and detection counts on shared cloud/CDN ranges can be misleading when read in isolation
- ASN and hosting-provider ownership must be checked before recommending an IP-level block
- Blocking a shared CDN IP risks denying access to thousands of unrelated, legitimate sites — a containment action that causes more damage than the threat itself
- The correct response for shared infrastructure is to avoid blocking the IP, focus containment on the specific malicious domain/URL, and report abuse directly to the hosting provider

11. Conclusion

Together, these two exercises demonstrate both the technical mechanics of phishing detection — header analysis, IOC extraction, and MITRE ATT&CK mapping — and the analytical judgment required to question a misleading threat-intelligence signal rather than act on it automatically. That distinction, between following an alert and evaluating it, is a core part of what separates L1 alert-triage work from analyst-level decision-making.

— Sojwal Jichkar | SOC Portfolio Project | 2026